

REPORTE DE HARDENING

GNU/Linux — Servidor de WebAPI

Documento	Reporte de Pruebas de Acceso Remoto y Hardening
Version	1.0
Clasificacion	Confidencial
Norma de referencia	ISO/IEC 27001:2022 — Anexo A
Servidor	Ubuntu 24.04 LTS — 165.22.189.121
Autor	Andres Martin Sinecio
Fecha	Mayo 2026

<https://youtu.be/q86fjyAyNjI>

1. Introduccion

El presente documento describe las actividades de hardening realizadas sobre un servidor GNU/Linux Ubuntu 24.04 LTS con el objetivo de asegurar los servicios y accesos remotos que sustentan la operacion de una WebAPI. Las medidas implementadas se alinean con los controles del Anexo A de la norma ISO/IEC 27001:2022, en particular con los dominios de Control de Acceso (A.8), Gestion de Criptografia (A.8.24) y Continuidad del Negocio (A.5.29).

1.1 Objetivo

Asegurar los servicios y accesos basicos del servidor GNU/Linux que aloja la WebAPI, reduciendo la superficie de ataque mediante controles de acceso, autenticacion multifactor, firewall y respaldo automatico.

1.2 Alcance

El alcance de este documento abarca:

- Servicio SSH con puerto no estandar y acceso por clave publica
- Autenticacion multifactor (MFA) mediante TOTP con Google Authenticator
- Gestion de cuentas de usuario (root prohibido, usuarios con distintos niveles de acceso)
- Configuracion de Firewall (UFW) con politica deny-by-default
- Proceso automatico de respaldo bajo la regla 3-2-1

2. Informacion del Sistema

Parametro	Valor
Sistema Operativo	Ubuntu 24.04.3 LTS (GNU/Linux 6.8.0-71-generic x86_64)
Direccion IP Publica	165.22.189.121
Proveedor	DigitalOcean (NYC1)
Recursos	1 vCPU, 512 MB RAM, 10 GB Disco
Servicio principal	WebAPI Python/Bottle con HTTPS (puerto 443)
Base de datos	MySQL 8.0.45
Puerto SSH configurado	2222 (no estandar por seguridad)
Firewall	UFW activo y habilitado al inicio

3. Controles de Seguridad Implementados

3.1 Endurecimiento del Servicio SSH

Referencia ISO/IEC 27001:2022: A.8.2 — Derechos de acceso privilegiado, A.8.5 — Autenticacion segura.

Control	Configuracion aplicada	Estado
Puerto SSH	Cambiado de 22 a 2222	APLICADO
Acceso root	PermitRootLogin no	APLICADO
Autenticacion por contraseña	PasswordAuthentication no (excepto usuario estudiante)	APLICADO
Autenticacion por clave publica	PubkeyAuthentication yes	APLICADO
Algoritmo de clave	ED25519 (256 bits)	APLICADO

Archivos de configuracion modificados:

```
/etc/ssh/sshd_config - PermitRootLogin no, PasswordAuthentication no
/etc/ssh/sshd_config.d/99-hardening.conf - Port 2222, PubkeyAuthentication yes
/etc/systemd/system/ssh.socket.d/override.conf - ListenStream=0.0.0.0:2222
```

3.2 Gestion de Cuentas de Usuario

Referencia ISO/IEC 27001:2022: A.8.2 — Derechos de acceso, A.8.3 — Restriccion de acceso.

Usuario	Metodo de acceso	Privilegios	Proposito
root	Deshabilitado por SSH	Superusuario	Solo acceso local
amsin	Clave privada ED25519 + TOTP	sudo	Administracion del servidor
estudiante	Contraseña unicamente	Sin sudo	Acceso de prueba/demostracion

3.3 Autenticacion Multifactor (MFA/TOTP)

Referencia ISO/IEC 27001:2022: A.8.5 — Autenticacion segura.

Se implemento autenticacion de dos factores para el usuario amsin mediante TOTP (Time-based One-Time Password) con Google Authenticator. El flujo de autenticacion SSH requiere:

- Factor 1: Clave privada ED25519 (algo que tienes)
- Factor 2:Codigo TOTP de 6 digitos, vigente por 30 segundos (algo que posees)

```
Paquete instalado: libpam-google-authenticator
```

```
PAM config: auth [success=done default=ignore] pam_google_authenticator.so nullok
```

3.4 Configuración de Firewall (UFW)

Referencia ISO/IEC 27001:2022: A.8.20 — Seguridad de redes, A.8.21 — Seguridad de servicios de red.

Puerto	Protocolo	Acción	Servicio
2222	TCP	ALLOW IN	SSH (puerto no estándar)
443	TCP	ALLOW IN	HTTPS / WebAPI
Cualquier otro	Cualquiera	DENY IN	Bloqueado por defecto
Saliente	Cualquiera	ALLOW OUT	Permitido por defecto

3.5 Proceso Automático de Respaldo (Regla 3-2-1)

Referencia ISO/IEC 27001:2022: A.8.13 — Copias de respaldo, A.5.29 — Seguridad durante interrupción.

La regla 3-2-1 establece: 3 copias, en 2 medios distintos, con 1 copia fuera del sitio (offsite).

Copia	Tipo	Destino	Formato
Copia 1	Archivos de la WebAPI	/opt/backups/ (mismo servidor)	TAR.GZ
Copia 2	Base de datos MySQL	/opt/backups/ (mismo servidor)	SQL.GZ
Copia 3	Repositorio completo	GitHub (offsite / nube)	TAR.GZ via Git

```
Script: /opt/backup.sh
```

```
Cron: 1 1 * * * /opt/backup.sh >> /var/log/backup.log 2>&1
```

El respaldo se ejecuta automáticamente todos los días a la 1:01 AM.

4. Pruebas de Acceso Remoto

ID	Prueba	Resultado esperado	Resultado obtenido	Estado
PR-01	Acceso SSH como root	Acceso denegado	Permission denied (publickey)	PASS
PR-02	SSH por contraseña como amsin	Acceso denegado	Permission denied	PASS
PR-03	SSH clave privada sin TOTP (amsin)	Solicitar código TOTP	Solicita verification code	PASS
PR-04	SSH clave privada + TOTP correcto (amsin)	Acceso concedido	Acceso exitoso al servidor	PASS
PR-05	SSH contraseña como estudiante	Acceso sin TOTP	Acceso exitoso	PASS
PR-06	Conexión al puerto 22 (antiguo)	Conexión rechazada	Connection refused	PASS
PR-07	HTTPS WebAPI puerto 443	Respuesta JSON de la API	HTTP 200 / JSON response	PASS
PR-08	Puerto no autorizado (ej. 8080)	Bloqueado por UFW	Connection timed out	PASS
PR-09	Ejecución manual del script de respaldo	3 copias generadas	Backup completado exitosamente	PASS
PR-10	Cron job a la 1:01 AM	Tarea programada activa	Cron job registrado y activo	PASS

5. Matriz de Cumplimiento ISO/IEC 27001:2022

Control	Descripcion	Implementacion	Estado
A.8.2	Derechos de acceso privilegiado	Root deshabilitado en SSH, sudo controlado para amsin	CUMPLIDO
A.8.3	Restriccion de acceso	UFW deny-by-default, solo puertos 443 y 2222 abiertos	CUMPLIDO
A.8.5	Autenticacion segura	SSH con clave ED25519 + TOTP para usuario amsin	CUMPLIDO
A.8.20	Seguridad de redes	UFW activo, puertos innecesarios bloqueados	CUMPLIDO
A.8.21	Seguridad de servicios de red	HTTPS con certificado mkcert en puerto 443	CUMPLIDO
A.8.24	Uso de criptografia	TLS/HTTPS para WebAPI, claves ED25519, bcrypt para contraseñas	CUMPLIDO
A.8.13	Copias de respaldo	Regla 3-2-1 con script automatico y cron a la 1:01 AM	CUMPLIDO
A.5.29	Seguridad durante interrupcion	Respaldo offsite en GitHub, logs en /var/log/backup.log	CUMPLIDO

6. Conclusiones

Se implementaron exitosamente los controles de seguridad del Anexo A de la norma ISO/IEC 27001:2022 sobre el servidor GNU/Linux Ubuntu 24.04 LTS. Los resultados de las pruebas de acceso remoto demuestran que:

- El acceso SSH esta correctamente restringido al puerto 2222 con MFA para usuarios administrativos.
- El usuario root no puede acceder remotamente, eliminando el vector de ataque mas comun en servidores Linux.
- El firewall UFW bloquea todo el trafico no autorizado, permitiendo unicamente SSH (2222) y HTTPS (443).
- El proceso de respaldo automatico 3-2-1 garantiza la disponibilidad de la informacion ante posibles fallos.
- La WebAPI opera bajo HTTPS protegiendo la comunicacion cliente-servidor.

Todos los controles implementados superaron satisfactoriamente las 10 pruebas de acceso remoto definidas (10/10 PASS), validando la efectividad del proceso de hardening realizado.
